Gift of the Givers · Relief Management System

DELIVERABLE 06

Implementation Plan

What has been delivered, what remains, and the order to build it in — with acceptance criteria and preliminary estimates.

DOCUMENT	VERSION	DATE	STATUS
D-06	2.0	2026-11-02	Current — Phase 0 complete, Phase 1 next

CONTENTS

1. Planning principles
2. Milestones
3. Phase 0 — Audit remediation (complete)
4. Phase 1 — Production candidate (next)
5. Phase 2 — Engineering quality and features
6. Phase 3 — Strategic
7. Risks to the plan

1. Planning principles

1. **Order by dependency, not just severity.** Tests and CI gates come before refactors; legal and merchant prerequisites come before real money.
2. **Every task closes a finding or a requirement.** Task IDs reference audit finding IDs (`F-nn`) or requirement IDs (`FR-nn` , `NFR-…`).
3. **Definition of done** (applies to every task): code with an integration test, CI green (tests, vulnerability gate, drift check, migrations on SQL Server), audit entries for staff actions, docs updated, finding status updated in `docs/audits/findings-register.json` .
4. **Estimates are preliminary** (one developer familiar with ASP.NET Core). The main uncertainties are external: PayFast onboarding, legal review and Azure access.

2. Milestones

Milestone	Exit criteria	Target maturity
M0 — Stabilised (done, 2026-11-02)	No open Critical findings; money integrity; staff access controlled; 98 tests; CI gates	Beta
M1 — Production candidate	F-23 closed (sandbox payment end to end), live environment verified, backups tested, legal review of privacy, staff MFA, monitoring and alerts	Production candidate
M2 — Production	Live merchant, PBO details, first real donation reconciled, runbooks rehearsed	Production ready
M3 — Growth	Recurring billing, live FX, retention automation, reporting	Mature

3. Phase 0 — Audit remediation (complete)

Task	Outcome	Findings closed	Status
T-0.1	Registration always creates Donor; Staff Access page; bootstrap staff via configuration	F-01	Done
T-0.2	Function key, reference lookup, verified-only certificates	F-02	Done
T-0.3	`DonationService` : pending capture, single verified increment, amount/merchant checks, idempotency	F-03, F-04, F-20	Done
T-0.4	Rand normalisation (`AmountZar` , rates) with historical backfill	F-05	Done
T-0.5	PayFast checkout wired; return, cancel and receipt by reference; options validator	F-06 (partial)	Done, E2E pending

Task	Outcome	Findings closed	Status
T-0.6	Certificates verified-only; issuer from configuration; demo watermark	F-07, F-40	Done
T-0.7	Patched crypto packages; source mapping; audit sources	F-08, F-24, F-25	Done
T-0.8	Privacy notice, consent capture, no invented data	F-09 (partial), F-32	Done, legal review pending
T-0.9	Validation and error display on all forms	F-16	Done
T-0.10	Rate limiting, security headers, SRI, Data Protection keys, forwarded headers	F-12, F-15, F-19, F-44	Done
T-0.11	Offline funds + Funding Reconciliation	F-03	Done
T-0.12	Audit log for all staff actions; paging; navigation	F-28, F-30, F-41	Done
T-0.13	Volunteer assignment UI; donation CSV export	FR-33, FR-34	Done
T-0.14	Migration chain fixed for empty databases; drift unsuppressed; remediation migration	F-11, F-21, F-22	Done
T-0.15	CI: locked restore, coverage, vuln gate, drift, SQL Server migrations; CD gated; publish fixed	F-14, F-34	Done
T-0.16	Live impact stats; organisation config; honest copy; accent contrast	F-18, D-03	Done
T-0.17	Docs: README, setup, contributing, security, PR template, deliverables 01–08	F-35	Done

4. Phase 1 — Production candidate (next)

Task	Problem / evidence	Desired outcome	Areas	Effort	Depends on	Acceptance criteria	Tests
T-1.1 Verify payments end to end	F-23: shared sandbox rejects signatures	Own PayFast sandbox merchant with passphrase; sandbox payment completes and the ITN verifies the donation	Config, ops	0.5–1 d	PayFast sandbox account; public tunnel or staging URL	A real sandbox payment shows *Paid*, the project total increases once, audit entry `PaymentVerified`	Manual script recorded in the addendum; keep the integration tests
T-1.2 Verify the live environment	F-10, F-02	App Service runs Production; demo accounts removed; old anonymous function removed	Azure	2–4 h	Azure access	`/ApplyDatabaseMigrations` absent; no demo logins; function returns 401 without a key	Smoke checklist
T-1.3 Staff MFA and lockout	F-36	Scaffolded Login with `lockoutOnFailure: true`; TOTP MFA required for Employees	Identity pages, policy	1–2 d	—	5 failed logins lock for 15 min; Employee pages redirect to MFA setup until enabled	Integration tests for lockout and the MFA policy
T-1.4 Backups and restore drill	F-17	Azure SQL PITR retention confirmed; documented restore to a copy	Ops, docs	0.5 d	Azure access	Restore performed and timed; RPO/RTO recorded in 07	Drill record
T-1.5 Monitoring and alerts	F-38	Application Insights (or OpenTelemetry); alerts on 5xx rate, health failures, ITN rejections	Program.cs, Azure	1 d	Azure access	Alert fires in a test; dashboards exist	Synthetic check
T-1.6 Production migration step	F-13	`Database:MigrateOnStartup=false`; pipeline applies `migrate.sql` before deploy	Pipelines	0.5 d	T-1.2	Deploy log shows the script step; app starts with no pending migrations	Pipeline run
T-1.7 Privacy sign-off	F-09	Legal review of the notice; Information Officer named; retention periods confirmed	Content, config	External	Organisation	Notice banner removed; `Organisation:InformationOfficerEmail` set	Content review
T-1.8 Reconcile live data	F-03	Funding Reconciliation run on the live database after deploy	Ops	1 h	T-1.6	All projects balanced or accepted with audit entries	Audit log
T-1.9 Review existing staff accounts	F-01	Self-registered Employee accounts revoked	Ops	1 h	T-1.2	Staff list matches the real team	Audit log

5. Phase 2 — Engineering quality and features

Task	Outcome	Findings / requirements	Effort
T-2.1	Recurring billing through PayFast subscriptions: subscription token, child donation per ITN, cancel from the donor portal	F-37, FR-18	4–6 d
T-2.2	Exchange-rate table with effective dates (staff-maintained or provider-fed); rate shown on the receipt	F-46	2–3 d
T-2.3	Extract `GiftOfTheGivers.Data` (DbContext, models, PDF) used by web and function; function deploy job and tests	F-29, F-42	2 d
T-2.4	Retention jobs (purge or anonymise per policy); staff deletion of volunteers and inquiries; data export for privacy requests	NFR-PRIV-03	2–3 d
T-2.5	Playwright smoke tests + axe accessibility checks in CI (donate, volunteer, register, staff pages; desktop and mobile)	NFR-A11Y-01, F-39	2 d
T-2.6	Move inline scripts and styles to files; strict CSP with nonces	F-19, D-01	1–2 d
T-2.7	Reporting: monthly totals per project and currency, volunteer pipeline	FR-34	2 d
T-2.8	Self-host fonts and icons	D-05	0.5 d
T-2.9	Load test (k6) of public pages and the ITN; record p95	NFR-PERF-02	1 d

6. Phase 3 — Strategic

Task	Outcome	Effort
T-3.1	Bicep IaC for App Service (Standard tier with slots), Azure SQL, Function App, Key Vault	3–4 d
T-3.2	Blue/green deploys with slot swap and automatic rollback on failed health	1–2 d
T-3.3	Consolidate on one CI system (GitHub Actions or Azure Pipelines)	1 d
T-3.4	Notification centre (email templates, retries via a queue)	3 d

7. Risks to the plan

Risk	Impact	Mitigation
PayFast onboarding delays	Blocks M1/M2	Start the merchant application now; keep the sandbox path working
Legal review unavailable	Blocks collecting real volunteer data	Keep `IsDemo` and the draft banner until signed off
Single maintainer	Bus factor	PR template, CI gates, these documents, audit register
Free hosting tier	No slots, cold starts	T-3.1 before real traffic